



Security in Networked AI Systems

Protecting data, models, and infrastructure end-to-end

The AI Security Threat Landscape

Modern AI systems face a complex array of threats that target every layer of the stack

Data Exfiltration & Training Data Theft

Attackers target valuable training datasets and proprietary model weights

Model Endpoint Abuse & Scraping

Unauthorized extraction of model capabilities through inference API manipulation

Lateral Movement in Clusters

Compromised containers or VMs used to pivot through K8s environments

Supply-Chain Risks

Compromised container images, libraries, and pre-trained models introducing backdoors

DDoS & Cost-Exhaustion Attacks

Targeting inference endpoints to drain compute resources and drive up cloud costs

Zero-Trust Principles for AI Infrastructure



Never Trust; Always Verify

Validate every request, regardless of source network or originating service



Strong Identity Everywhere

Cryptographic identities for users, services, nodes, and workloads



Continuous Policy Enforcement

Apply least privilege across stack with dynamic policy evaluation



Assume Breach

Segment aggressively and monitor for anomalous behavior





Identity, Authentication & Authorization

Identity Standards

- OIDC/OAuth2 for human users
- SPIFFE/SPIRE for workloads
- Federated identity across clouds

Access Controls

- Short-lived credentials
- Just-in-time (JIT) access
- Break-glass emergency procedures

Permission Models

- RBAC for role-based permissions
- ABAC for attribute-based controls
- Fine-grained policy enforcement



Critical Security Control: Block long-lived secrets and enforce regular rotation of all keys and tokens in your AI infrastructure

Network Segmentation for AI Workloads

Defense-in-Depth Networking

Cloud Network Isolation

VPCs/VNETs with private subnets and no public IPs by default

Tenant Isolation

VRFs/VXLAN for multi-tenant separation; Kubernetes NetworkPolicies

Layer 7 Filtering

eBPF datapaths (e.g., Cilium) for L3-L7 policy enforcement

Gateway Controls

Ingress/egress gateways with explicit allow-lists for permitted traffic



Secrets & Key Management

Secure storage and access control for the sensitive materials that protect your AI assets



Secure Storage

Use managed KMS/HSM + HashiCorp Vault for secret storage with hardware security backing



Deployment Security

No secrets in images or env files; use sidecars or CSI for runtime injection



Encryption Practices

Implement envelope encryption, automated key rotation, and comprehensive access logs



Environment Isolation

Maintain separate encryption keys per environment (dev/stage/prod)

Encryption Everywhere



Transport Security

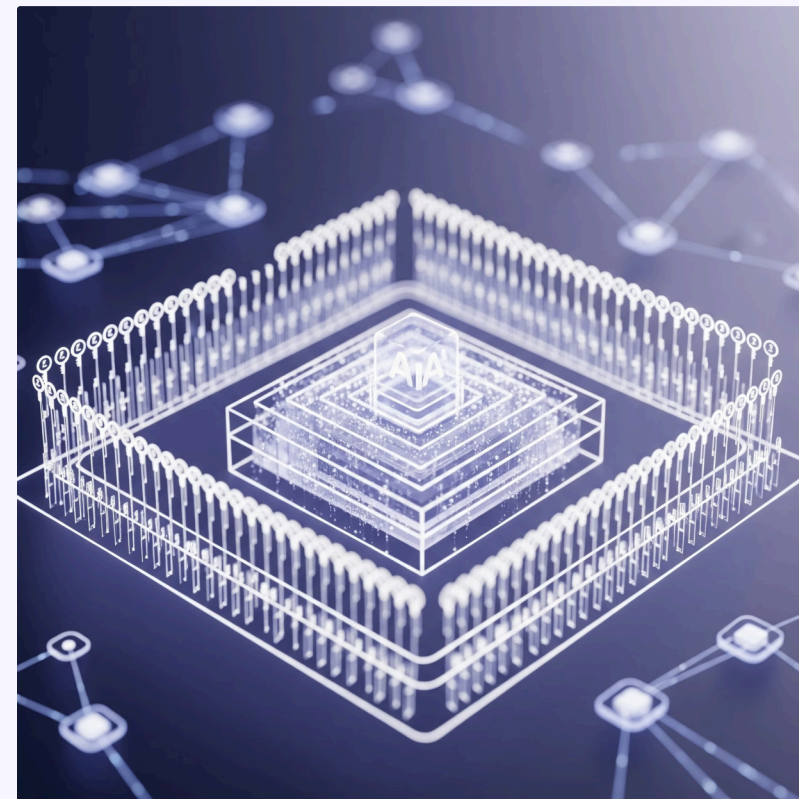
- **mTLS** for all service-to-service communication
- TLS 1.2+ at network edges with strong cipher suites
- MACsec/IPsec for DC/Inter-region links where needed



Data at Rest

- Encrypted disks, object stores, and databases
- Customer-managed encryption keys (CMEK)
- Encryption for model weights, checkpoints, and logs

- ❑ Performance Consideration: Align MTU/QoS settings to ensure encryption doesn't impact performance



API & Model Endpoint Security



Request Verification

JWT-based authentication + scope/claim authorization on every API call



Edge Protection

WAF + rate limits + circuit breakers to protect inference endpoints



Input Defense

Strict input validation & schema enforcement (gRPC/JSON schemas)



Usage Controls

Anti-automation/bot protections with per-tenant usage quotas



Kubernetes & Runtime Hardening

Securing the orchestration platform that runs your AI/ML workloads



Pod Security

- Apply PodSecurity standards (restricted profile)
- Minimal privileges, read-only root filesystems
- Non-root users and groups for containers



Isolation Controls

- Limit hostPath mounts, disable privilege escalation
- Implement seccomp profiles and AppArmor policies
- Resource quotas and limit ranges



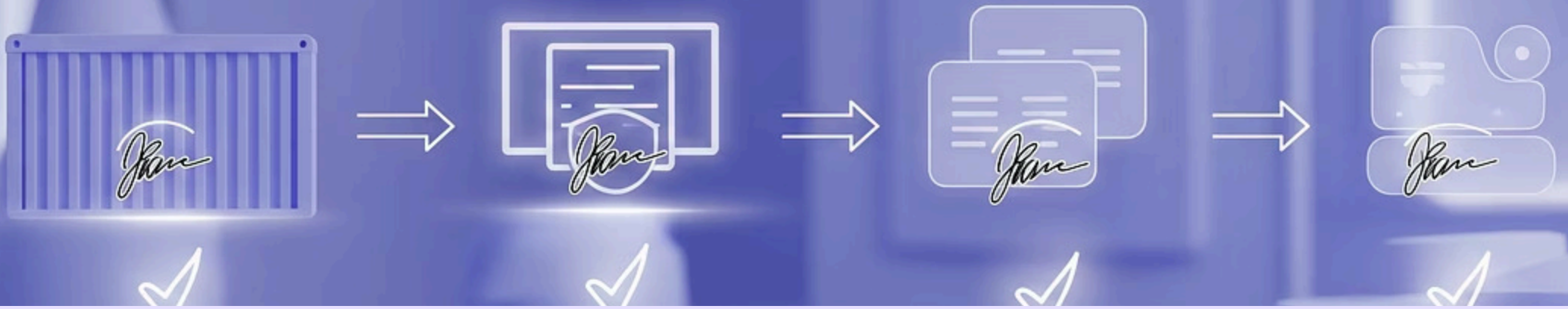
Image Security

- Image provenance verification (sign with cosign)
- Pull from private registries with authentication
- Base images from trusted sources only



Runtime Protection

- Runtime detection with Falco
- Admission control using OPA/Gatekeeper
- Network policy enforcement



Supply Chain & Artifact Security

Provenance & Verification

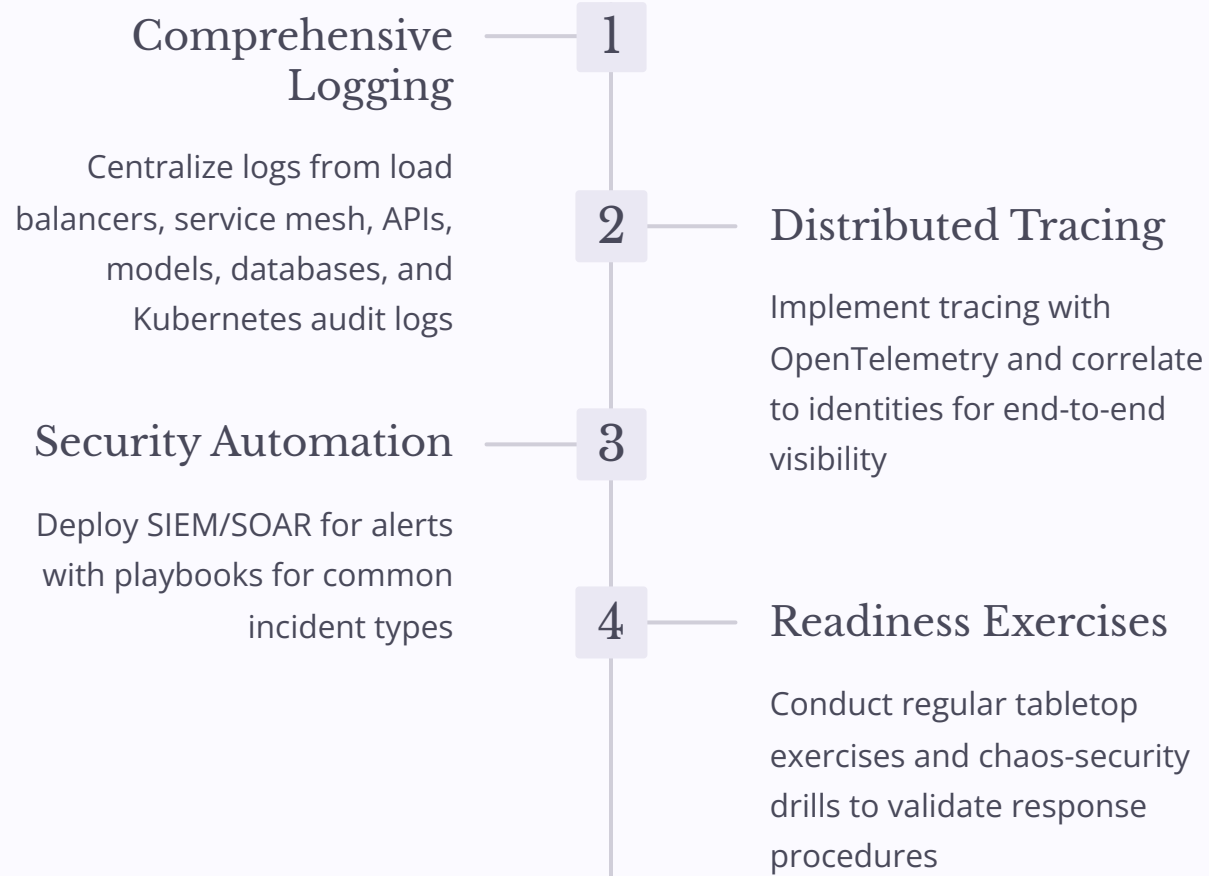
- Generate SBOMs with SLSA provenance for all artifacts
- Pin dependency versions & cryptographic hashes
- Verify model artifacts (hashes, signatures) before deployment

Build Security

- Scan containers/dependencies in CI pipeline
- Block deployments with critical vulnerabilities
- Separate build and runtime networks/accounts

⊗ Supply chain attacks are increasingly targeting AI/ML components - verify everything before it enters your environment

Observability, Detection & Response



Data Security & Governance for AI Systems



Classification & Control

- Classify all data (PII/PHI/IP) with appropriate tags
- Implement DLP rules based on data classification
- Apply row/column-level access controls
- Enforce purpose-limited data access

Data Lifecycle Management

- Minimize data retention periods
- Implement tiered storage strategies
- Tokenize sensitive data where possible
- Purge data when no longer needed

Transfer Monitoring

- Monitor all data egress points
- Track cross-region transfers
- Log all data sharing activities
- Alert on anomalous data movement



Resilience & DDoS Mitigation

Infrastructure Defense

- Implement Anycast routing and L4 shield protection
- Configure autoscaling with appropriate buffer capacity
- Design request shedding mechanisms for extreme loads
- Deploy regional isolation with failover runbooks

Performance Protection

- Establish priority queues to protect critical tenants
- Deploy caches and read replicas to absorb traffic spikes
- Monitor p95/p99 latency metrics as early warning
- Implement circuit breakers to prevent cascading failures

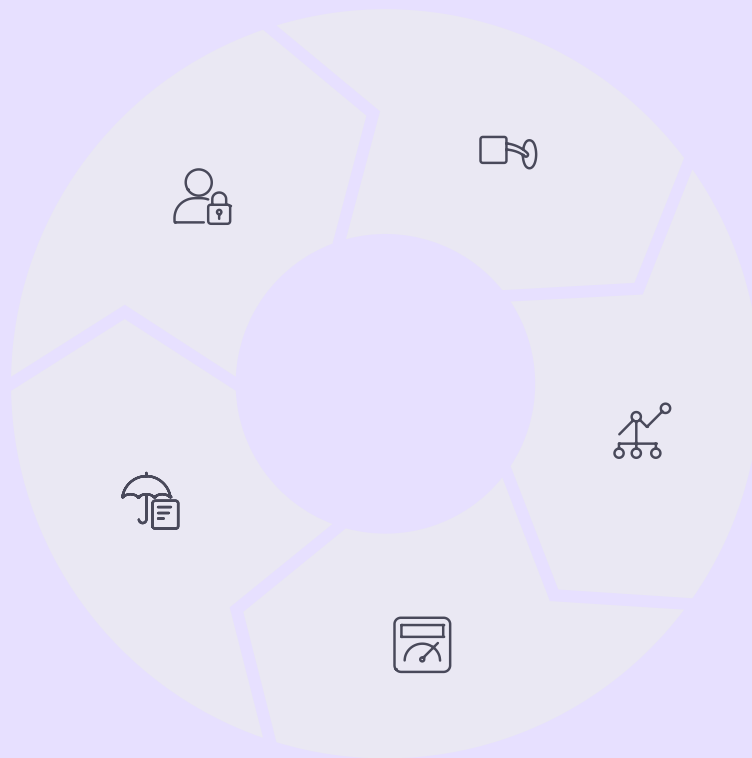
Best Practices & Key Takeaways

Default-Deny Architecture

Implement least-privilege access controls across the entire stack

Response Automation

Instrument, rehearse, and automate the security response loop



Encryption & Authentication

Enforce **mTLS**, rotate keys regularly, verify all artifacts

Tenant Isolation

Segment tenants at network, compute, and storage layers

Continuous Monitoring

Watch p95/p99 latency and error rates as security indicators